

SCHOOL OF INFORMATICS & IT
DIPLOMA IN CYBERSECURITY & DIGITAL FORENSICS

CCD2C08 – SECURE WEB APPLICATIONS (SWAP)
AY 2025/2026 OCTOBER SEMESTER

Project (50%)

Name (Admin No.): Abdul Kapoor Asbar Firnas (2403219E)
Name (Admin No.): Haja Najumudeen Mohamed Hasif (2400251A)
Name (Admin No.): Loke Si Xuan (2400542C)
Name (Admin No.): Naw May Thet Htar (2403220C)

Tutor : Chern Nam Yap

Submission Date : 13 December 2025, 23:59

Declaration of Originality

I am the originator of this work, and I have appropriately acknowledged all other original sources used as my references for this work.

I understand that Plagiarism is the act of taking and using the whole or any part of another person's work, including work generated by AI, and presenting it as my own.

I understand that Plagiarism is an academic offence and if I am found to have committed or abetted the offence of plagiarism in relation to this submitted work, disciplinary action will be enforced.

Declaration on the use of Generative AI tools for assignments

Describe how you have used Generative AI tools such as ChatGPT or Dall.E- in your assignment.

Share the link to the conversations you had with the AI tool (i.e., the prompts you used and the responses you get from the AI tool).

How do you indicate the reference?

The content generated by AI tools are not retrievable except by the user who generated them, so they are considered non-recoverable sources. Although non-recoverable data or quotations in APA Style papers are usually cited as personal communications, with ChatGPT-generated text there is no person communicating. Quoting text from ChatGPT chat is therefore more like sharing the output of an algorithm, with a reference list entry and the corresponding in-text citation.

According to the official APA Style site, ChatGPT references should be cited as:
E.g. OpenAI. (2024). *ChatGPT* (Feb 13 version) [Large language model].

<https://chat.openai.com/chat>

Note: The information in parentheses refers to the update or revision date of the model used. Refer to the release notes in the ChatGPT application.

Important Note:

- Do not copy answers produced by the AI tool in totality as it is considered as plagiarism.
- Do not rely on any information produced by the AI tool blindly. You should always verify the answer with other sources. Do not assume that these answers provided by the AI tool are correct.
- To achieve quality outputs from the AI tool, you should provide good prompt that is clear and specific. Be precise and provide context. Avoid asking open-ended questions.

Table of Contents

1.	Introduction	6
1.1	Introducing the Team	6
1.2	Brief Overview.....	6
1.3	Main Problem.....	6
1.4	Solution: Real-Time Equipment Condition & Damage Tracking System.....	7
2.	Problem Statement	8
2.1	Equipment Availability	8
2.2	Equipment Health	8
2.3	Damage Trends	8
2.4	User Accountability	9
3.	Web Application Proposal	11
3.1	Equipment Availability	11
3.2	Equipment Health	11
3.3	Damage Trends	12
3.4	User Accountability	12
4.	Project Delivery	14
4.1	Gantt Chart	14
4.2	Overview	14
4.3	Planning Phase.....	14
4.4	Design Phase.....	15
4.5	Development Phase.....	15
4.6	Testing Phase	16
4.7	Documentation Phase.....	16
4.8	Presentation Phase.....	16
5.	Use Cases	17
5.1	Add and Remove Equipment Form	17
5.2	Alert Details.....	18
5.3	Damage Trends Dashboard.....	19
5.4	Check In and Check Out Condition Report	20
6.	Abuse/ Misuse Cases	21
6.1	Misuse Case for Add and Remove Equipment Form	21
6.2	Misuse Case for Alert Details.....	23
6.3	Misuse Cases for Damage Trends.....	24
6.4	Misuse Case for Check In and Check Out Condition Report	25
7.	Threat Modelling	27
7.1	Choice of Framework.....	27
7.2	Threat Analysis for Add and Remove Equipment Form	27

7.3 Threat Analysis for Alert Details	27
7.4 Threat Analysis for Damage Trends Dashboard	28
7.5 Threat Analysis for Check In and Check Out Condition Report	28
7.6 Mitigation Controls for Add and Remove Equipment Form	29
7.6 Mitigation Controls for Alert Details	29
7.6 Mitigation Controls for Damage Trends Dashboard	30
7.6 Mitigation Controls for Check In and Check Out Condition Report	31
8. Non-Functional Requirements	33
8.1 Security	33
8.1.1 Security in relation to Add and Remove Equipment Form.....	33
8.1.2 Security in relation to	33
8.1.3 Security in relation to Check In and Check Out Condition Report.....	33
8.2 Reliability	35
8.2.1 Reliability in relation to Add and Remove Equipment Form	35
8.2.2 Reliability in relation to Alert Details	35
8.2.3 Reliability in relation to Check In and Check Out Condition Report	36
8.3 Compliance	36
8.3.1 Compliance in relation to Add and Remove Equipment Form.....	36
8.4 Performance	36
8.4.1 Performance in relation to Add and Remove Equipment Form	36
8.4.2 Performance in relation to Check In and Check Out Condition Report	37
8.5 Maintainability	37
8.5.1 Maintainability in relation to Add and Remove Equipment Form.....	37
8.5.2 Maintainability in relation to Check In and Check Out Condition Report	37
8.6 Usability	38
8.6.1 Usability in relation to Add and Remove Equipment Form	38
8.6.2 Usability in relation to Check In and Check Out Condition Report	38
9. Test Plan / Considerations	40
9.1 Add and Remove Equipment Form	40
9.2 Alert Details.....	40
9.3 Damage Trends Dashboard.....	41
9.4 Check In and Check Out Condition Report	41
10. Workload Distribution	45
11. References / Acknowledgements.....	48
12. Appendix	49

1. Introduction

1.1 Introducing the Team

This document serves as the formal project proposal and comprehensive security analysis for the CCD2C08 Secure Web Applications project. We are a group of students, Hasif, Asbar, Naw May, and Si Xuan, tasked with designing and developing a PHP secure web application for the TP Advanced Manufacturing Centre (AMC). The primary objective is to manage equipment information in a database securely while effectively addressing real-world operational problems faced by the AMC. The project scope is comprehensive, including implementing secure CRUD (Create, Read, Update, Delete) functionalities, views for users with varying roles, defining at least five misuse cases, and implementing robust codes against common web vulnerabilities. Our team is committed to meeting these requirements using PHP libraries, MySQL, and following best practices in secure web development to deliver a robust and effective solution for the TP AMC.

1.2 Brief Overview

The TP Advanced Manufacturing Centre (AMC) supports a wide range of teaching, learning, and industry-related activities through the use of shared specialised equipment. These equipment items are frequently loaned to students and staff for lessons, laboratory sessions, projects, and external collaborations, resulting in high utilisation across different users and time periods.

While existing systems may provide real-time monitoring or operational visibility, effective equipment management also requires the ability to review historical data and identify recurring issues over time. When damage-related information is not consolidated or presented in an analytical manner, staff may face challenges in identifying patterns, prioritising maintenance efforts, and planning long-term resource allocation.

To address this gap, the proposed system places emphasis on improving visibility into equipment condition history and damage trends. By supporting trend-based analysis, AMC can enhance proactive maintenance planning and informed decision-making beyond immediate real-time monitoring.

1.3 Main Problem

At TP Advanced Manufacturing Centre (AMC), a range of equipment is being loaned and is available for industry partners, companies and students for training, upskilling and learning. The equipment is crucial and is the core of TP AMC manufacturing and training capabilities. Thus, we will be focusing on the Manufacturing department for this web application.

With so many users of different backgrounds, there is a significant risk of equipment mismanagement. Equipment mismanagement can lead to problems in equipment availability, equipment health, inaccurate damage trends, and user accountability.

1.4 Solution: Real-Time Equipment Condition & Damage Tracking System

To solve these problems of equipment misuse, discrepancies with reporting conditions, and late detection of any damage, we offer a solution through our suggested Real-Time Equipment Condition & Damage Tracking System. It will provide an integrated internet platform for all equipment status information, and there will be immediate reporting on any problems with equipment status, and staff members will be able access it.

The system will comprise the compulsory reporting feature for conditions at check-in and check-out times, which will result in the recording of all usage with updated health conditions. A user will be able to make immediate reports on damages with images and descriptions. The reports will automatically generate an alert that will be visible on the dashboard, which will be accessible via an Alert Details page. A detailed report will be shown on the Alert Details page, including all necessary information about the alert and its status.

By blending alert functionality, detailed logs, and automatic accountability tracking functionality, it enhances equipment reliability and increases efficiency and will enable the AMC to identify and detect patterns of damage. Overall, it will make the equipment management process more efficient and more secure for students and staff.

2. Problem Statement

2.1 Equipment Availability

The fundamental issue facing TP AMC is the absence of a simple, centralized system to track equipment. This core deficiency creates immediate uncertainty for staff and students, as they have no quick way to determine the real-time status of necessary tools, meaning they don't know where the equipment is physically located, if it's currently checked out by another user, or if it's functionally operational. This lack of visibility is directly tied to the administrative challenge of maintaining the master inventory list. Without a secure form for authorized personnel to add or remove assets, the database quickly loses synchronization with the physical assets, leading to inaccurate availability records that mislead users.

These tracking limitations lead to two major consequences that severely impact TP AMC operations. Firstly, there is significant wasted time and decreased productivity, as users must manually search for equipment, make multiple inquiries, or rely on outdated verbal confirmations to check availability, diverting focus from their core tasks. Secondly, the lack of immediate status data results in unforeseen project and teaching delays. When a critical piece of equipment is unexpectedly found to be unavailable or out of order at the moment it is needed, the delay makes efficient resource planning and allocation impossible, directly disrupting lessons, assessments, and industry collaboration deadlines.

2.2 Equipment Health

Within the AMC, equipment status or condition is currently monitored via various spreadsheets and verbal communications. The above-mentioned methods lead to discrepancies and missing data within records. Should any equipment be compromised or deteriorate, there lacks a platform for documenting said problem and tracking it based on multiple users.

Because these updates have to be done manually, it becomes evident that several problems become known only after the equipment fails completely. It leads to unwarranted downtimes and cancellations of bookings, and disgruntled employees who need guaranteed usage of properly functioning equipment. Irregular submissions make it more difficult for the AMC to spot some common trends, like common damaging or misuse from certain individuals.

Lack of documented health information leads to a loss of accountability, slows down the response rate for equipment availability, and raises maintenance costs. There is a need for an efficient system that can document equipment status at an immediate level and store historical health information.

2.3 Damage Trends

Although real-time monitoring systems may provide immediate visibility into equipment status, they may not fully support the analysis of historical damage patterns across equipment over extended periods. Damage-related information is

often recorded as individual incidents without being consolidated into trend-based views, making it difficult to identify recurring issues, high-risk equipment, or commonly occurring fault types.

The lack of clear damage trend analysis limits AMC's ability to move beyond reactive maintenance responses. Without historical insights, maintenance actions are typically taken only after repeated failures occur, which can disrupt lessons, assessments, and external events. From a planning and management perspective, the absence of structured damage trend visibility also makes it challenging to prioritise preventive maintenance, justify equipment replacement decisions, or allocate maintenance budgets effectively.

A successful system should therefore support the analysis of historical damage data in a consolidated and meaningful way, enabling proactive maintenance planning and more informed equipment management decisions.

2.4 User Accountability

The current TP AMC use the Nerve Centre as its tracking system. It provides real-time tracking for monitoring and controlling production, boosting productivity and operational performance. While it effectively manages the equipment to a certain extent, the system does not track which individual user operates each equipment and how long it is being used by the user. Although tracking with the usage of CCTVs is also possible, it can be more tedious and troublesome to be done.

The current system, Nerve Centre, captures machine activity but not user activity. Without proper authentication and identification of users operating the equipment, user accountability becomes a cause of concern. When equipment goes missing or damaged, there is no traceable link to the responsible person. This may cause arguments, conflicting reports, and blaming within the staffs, delaying the investigation process.

This lack of user accountability will lead to numerous of operation, management, and security-related problems:

1. Damaged or missing equipment cannot be accurately and efficiently traced to responsible user.
2. Administrators rely on verbal reports which can be false (accidental wrong blaming).
3. Investigations on the missing and misused equipment will be time-consuming due to insufficient traceability.
4. Equipment availability is hindered due to long investigations periods.
5. Increased risk of insider threat such as users misuse equipment with no liability.
6. No authentication needed to operate and use equipment.

Students and staff experience delays due to equipment being unavailable, misplaced or damaged. The management teams faced increased maintenance, operational inefficiencies, and replacement costs. While the security team have a lack of accurate data such as logs to perform reliable investigations efficiently.

The department requires a system to track each equipment usage to the current user reliably and efficiently. The tracking should be logged automatically with timestamps securely, no tampering should occur. This will ensure reduce equipment loss and damage, operational transparency, and a fair system for all users.

3. Web Application Proposal

3.1 Equipment Availability

To resolve the challenge of equipment availability, the system will feature a dedicated Equipment Inventory Management section accessible to authorized administrators and staff. This module will integrate with the main database to provide accurate, up-to-the-minute status updates for all listed assets.

The solution focuses on two key administrative and tracking functions:

1. Availability Display (Read Function, CRUD):
 - a. The main equipment listing page will serve as the central source of truth, displaying the real-time status of every item (e.g., 'Available', 'Checked Out', 'Under Maintenance', 'Damaged/Alert'). This status is dynamically updated by the check-in/check-out system (Si Xuan's part) and the health reports (Asbar's part), providing users with instant clarity on whether a tool is ready to use.
2. Admin Equipment Management Form (Create, Update, Delete Function, CRUD):
 - a. A secure, role-restricted interface will be implemented, accessible only by authorized administrators. This form enables them to perform the core Create, Update, and Delete (CRUD) functions required to maintain the master inventory list:
 - i. Add (Create): Register new equipment by entering mandatory details (asset tag, description, location) securely into the database. This action ensures the persistent storage of data.
 - ii. Update (Update): Modify existing equipment details, such as changing its designated location or manually setting its status to 'Under Maintenance'.
 - iii. Remove (Delete): Permanently remove equipment records, ensuring only administrators can perform this sensitive action.

This section ensures that the master inventory data is accurate and controlled, while simultaneously providing the centralized, real-time availability information needed to eliminate searching and delays.

3.2 Equipment Health

To solve the problems associated with inconsistent and inaccurate reporting, the Equipment Health module presents a structured and timely condition tracking system via the online application. Every equipment page will be equipped with its status at any given moment, recent records involving damage, and an easy-to-interpret record

of historical problems. Users will be able to report problems and attach images instantly.

Every time equipment is checked-in and checked-out, there is a mandatory report on its condition that needs to be filled out. This goes on to build a health trail and ensures that problems with equipment are detected at an early stage. All actions pertaining to equipment related to health, including updates and verifications, are tracked.

It enhances equipment reliability and reduces downtime. It also helps in taking repair and replacement decisions based on facts and current conditions.

3.3 Damage Trends

To complement existing operational and real-time monitoring capabilities, the proposed system includes a Damage Trends Dashboard designed to support long-term analysis and planning. While real-time systems are effective for immediate status visibility, equipment management also requires historical insights to identify recurring damage patterns and underlying issues that may not be apparent from individual incidents.

The Damage Trends Dashboard aggregates historical data from damage reports, condition records, and equipment availability logs to present consolidated analytical views. This allows authorised technicians and administrators to identify frequently damaged equipment, common fault types, and periods with higher rates of equipment issues. By transforming individual damage records into trend-based summaries, the dashboard supports informed decision-making related to preventive maintenance, equipment replacement, and resource allocation.

Rather than replacing existing monitoring tools, this feature enhances AMC's equipment management capabilities by providing a planning-focused perspective. The availability of damage trend insights enables staff to move from reactive responses towards proactive maintenance strategies, improving equipment reliability and operational continuity.

3.4 User Accountability

The Real-Time Equipment Condition & Damage Tracking System tracks who uses each equipment and for how long efficiently, enhancing user accountability. Every time an equipment is used, it will be checked in and the user information is logged. This ensures transparency in tracking, reducing disputes, and aiding the management team with investigations.

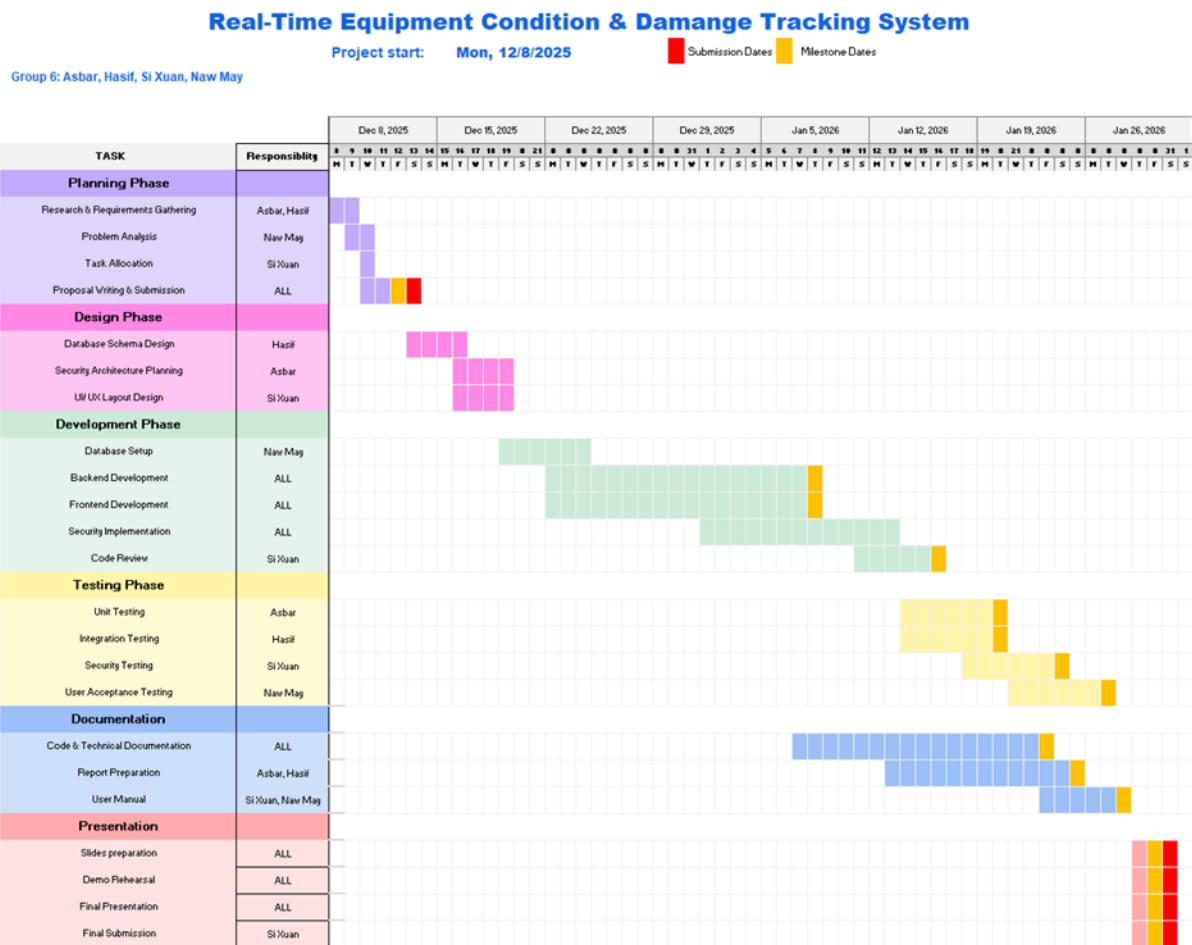
Problem Identified	Key Feature	How it Solves the Problem
Damaged or missing equipment cannot be accurately and efficiently traced to responsible user.	Register and log in. Check in to use equipment.	When an equipment is damaged or missing, the registered account that is used to check in is instantly logged in the system. This provides accurate logging for tracking.

Administrators rely on verbal reports which can be false (accidental wrong blaming).	Condition report done when checking out.	The condition report provides accurate data, making verbal reports unnecessary and unreliable.
Investigations on the missing and misused equipment will be time-consuming due to insufficient traceability.	Check in to use equipment. Condition report done when checking out.	Since check in and check out is being logged, there is data to back up the investigation instantaneously.
Equipment availability is hindered due to long investigations periods.	Check in to use equipment. Condition report done when checking out.	As mentioned above, investigation will be faster with the data to aid the investigation, allowing faster equipment availability.
Increased risk of insider threat such as users misuse equipment with no liability.	Register and log in. Check in to use equipment.	The system tracks the user using the equipment and is transparent about it, making users aware of their actions and know there is a responsibility to take when using the equipment.
No authentication needed to operate and use equipment.	Register and log in. Check in to use equipment.	Users are required to log in and check in to use an equipment ensuring that only authorised users are allowed to use, boosting safety as well.

Authenticated users are required to check in to be able to use and equipment. Once they are done with the equipment, they can check out where a condition report is compulsory to be done. The web ensures user log in and only authentication user can operate the equipment, providing secure authentication. The reports will show "Invalid Input" for SQL injection prevention and file upload prevention. The reports are also unable to be tamper by keeping timestamps of check in, submit condition report, and alterations, to ensure accountability. Only administrator can update the condition report as well. This helps TP AMC to operate smoothly with faster investigations, reduced insider threat, and better equipment availability.

4. Project Delivery

4.1 Gantt Chart



[Gantt Chart PDF Version](#)

4.2 Overview

The project delivery is structured to ensure that system planning, design, development, and testing are carried out in a logical and controlled manner. Each phase is aligned with specific deliverables to minimise integration risks and ensure that critical dependencies are addressed early. Core equipment data structures and reporting workflows are prioritised before analytics-related features to ensure data consistency, reliability, and meaningful historical insights.

By adopting a phased delivery approach, the team is able to validate foundational components before building higher-level functionalities such as dashboards and trend analysis for maintenance planning and decision support. This approach supports incremental development, improves coordination among team members, and reduces the likelihood of major rework during later stages of the project.

4.3 Planning Phase

The planning phase is made up of 4 sections, research and requirements gathering, problem analysis, task allocation, and proposal writing and submission. The research

and requirement gathering helps to identify the problems, impacts, and desired outcome of the project, ensuring a focused and detailed work. Problem analysis helps to identify the core problem and go deeper in each sub problem.

Task allocation is assigned to team members, and each member can start with their proposal writing. The task is broken down with timeline and based of each member skills to ensure complete and high-quality work while ensuring the team do not clash in their work. The finds will then be compiled and finalised into the proposal. The proposal highlights the research, problems, planning, solutions, use cases, and security considerations.

4.4 Design Phase

During the design phase, the system architecture and data structures are planned to support both operational workflows and long-term analysis. Special attention is given to how equipment records, condition reports, and damage logs are structured so that they can be efficiently aggregated for trend analysis without adversely affecting system performance.

For the damage trends feature, the design emphasises clear relationships between equipment, damage records, and timestamps. This allows historical data to be queried accurately in order to identify recurring issues, frequently damaged equipment, and periods where repeated failures occur. Role-based access control requirements are also incorporated at this stage to ensure that analytical dashboards are accessible only to authorised technicians and administrators.

By addressing data modelling and access control considerations early, the design phase reduces integration complexity during development and supports reliable analytics in later stages of the project. In addition, scalability is considered to ensure that damage trend analysis remains accurate and responsive as the volume of historical data increases over time.

4.5 Development Phase

The implementation of Equipment Health and Alert Details functionality will be done at two levels - backend and frontend. At the backend level, functionality will be created for generating database tables associated with health reports, damage reports, verification status, and alert metadata. CRUD APIs will be implemented at this level for handling equipment health data.

As regards the Front-end, an Equipment Health screen will be created. The Alert Details page will be implemented as an interactive component that will open upon a click on a message on the homepage. It will fetch the alert ID based on the notification and will then show incident information, user report, date and time, and associated media.

During the developmental stage, coding best practices involving input verification and escaping, prepared SQL statements, CSRF tokens, and role-based verification will be implemented so that the data related to health and alerts will not be manipulated or viewed incorrectly.

4.6 Testing Phase

The testing will concentrate on making sure that all health-related information is processed and shown properly. Unit tests will be done to make sure that uploading health reports, generating alerts, and status changes on alerts are done properly. Integration tests will be done to make sure that alerts created from check-in and check-out procedures relate properly to the Alert Details page.

Security testing would be implemented to protect against any unauthorized access into reports for sensitive equipment. System testing would be done to validate that Health and Alert modules work as they should with normal and boundary values, including a large number of previous reports.

All results will be documented, and all discrepancies identified will be cleared before incorporating them into the main system.

4.7 Documentation Phase

The documentation phase is ongoing throughout the Software Development Life Cycle (SDLC) but culminates in the creation and consolidation of the final deliverables for the entire group.

- **Project Proposal:** The initial documentation focuses on the problem statement, requirements gathering, planning, and threat modelling. This is a consolidated group report.
- **Code Documentation:** All code developed by team members will be well-commented, adhering to consistent naming conventions and clean architecture, as required for quality assessment. This includes documentation of security controls implemented for OWASP vulnerabilities.
- **Testing Documentation:** Comprehensive logs will be maintained for Unit (a single function), Integration (how your code works with other group members code), System (the final, complete system), and Acceptance (if the final system meets the user's needs) testing, including test procedures, results, and justification of security mitigations.
- **Final Submission Assets:** The team will consolidate the entire codebase, the necessary SQL scripts to re-create the database, and the presentation slides for final submission via LMS. The documentation must strictly follow the required naming conventions.

4.8 Presentation Phase

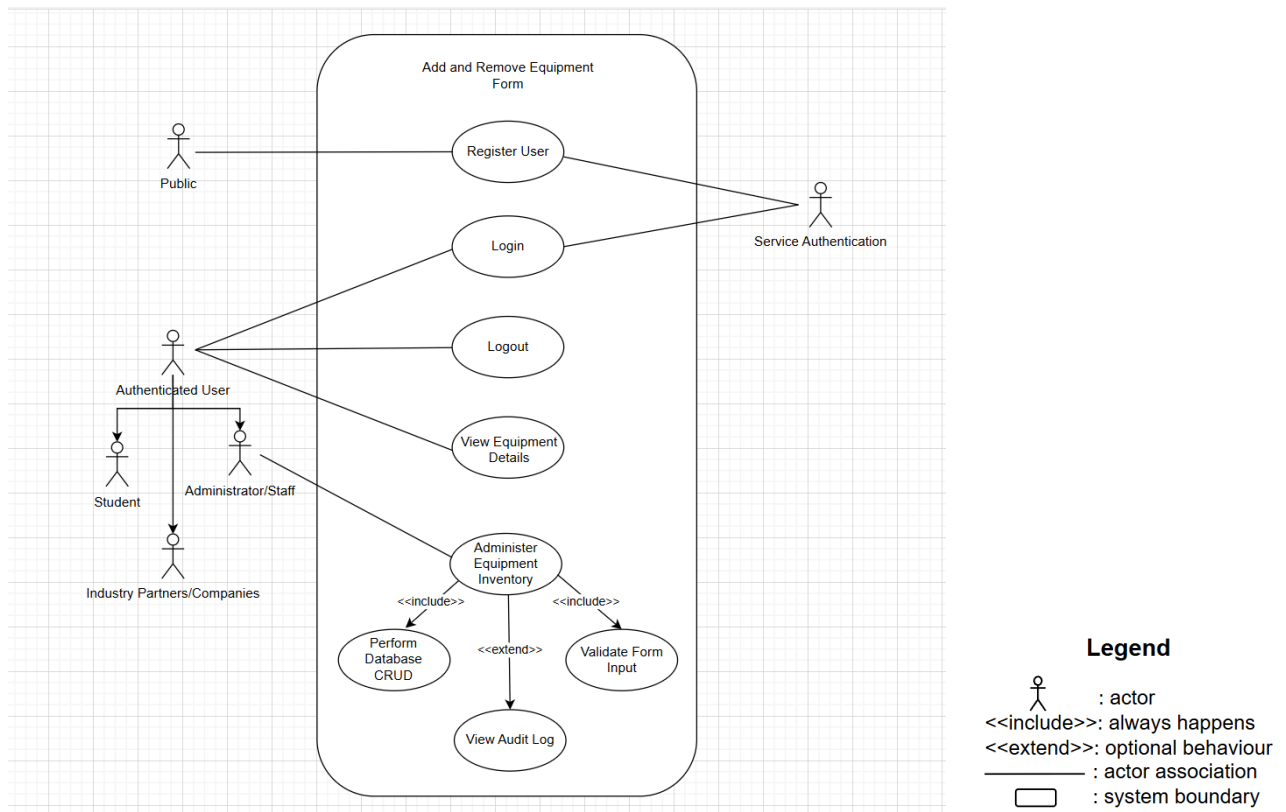
The presentation phase serves as the final submission component, demonstrating the working application and the security findings.

- **Demonstration:** Members will present their individual contributions, focusing on the functionality of their assigned module (e.g., the secure Admin Add/Remove Equipment Form for inventory management).
- **Acceptance Test:** The team will demonstrate that the completed system meets both the functional (e.g, all CRUD operations work) and non-functional requirements (e.g, security, reliability) defined in the proposal.
- **Security Analysis:** Each member will present their findings from the security testing, explaining the two OWASP Top 10 vulnerabilities they addressed, the risk analysis performed, and the effectiveness of the implemented security controls (e.g, preventing unauthorized access to the admin form).
- **Q&A:** Members must be prepared to answer individual questions from the tutor regarding their code, security approach, and overall contributions.

5. Use Cases

5.1 Add and Remove Equipment Form

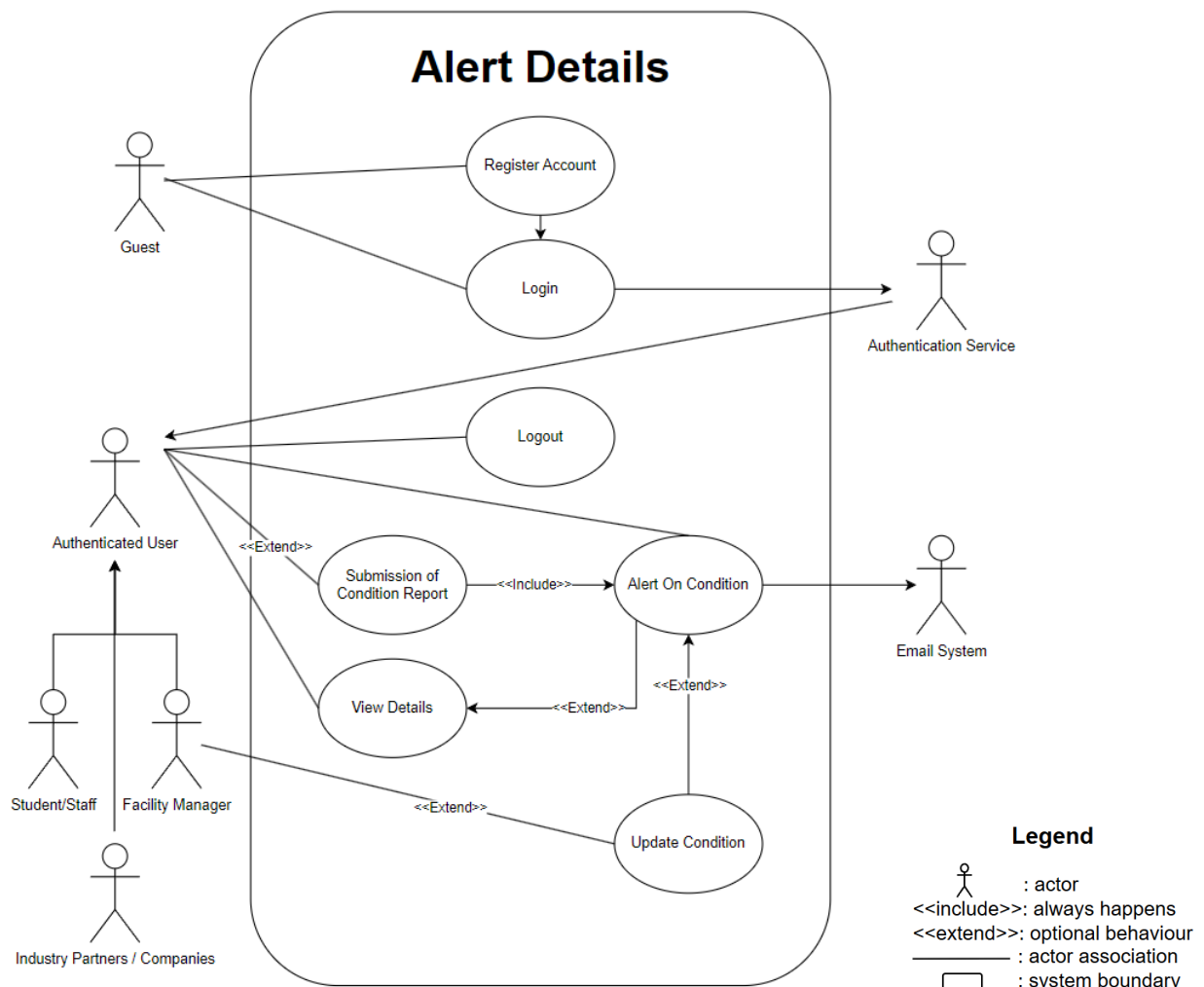
The primary goal of the Add and Remove Equipment Form use case is to allow an authorized Administrator to maintain the integrity of the master equipment inventory. This functionality encompasses both the creation and deletion of core asset records. The Add Equipment flow begins when the Administrator logs into the system, navigates to the Inventory Management page, and inputs the required new equipment details (e.g., Asset Tag, Description, Initial Location) into a dedicated form, which the system then validates and securely stores in the database. Crucially, every successful Create, Update, or Delete action immediately triggers the creation of a permanent Audit Log entry. This log records the specific change made, the equipment affected, the timestamp, and the identity of the Administrator who performed the action, ensuring full accountabilities for all high-privilege modifications. Conversely, the Remove Equipment flow is used when an asset is decommissioned or lost. The Administrator selects the item from the master list, confirms the deletion, and the system securely updates the database to either permanently remove the record or mark it as 'Decommissioned' for audit purposes. This high privilege use case is critical for ensuring the accuracy of all subsequent tracking and reporting performed by the other modules.



5.2 Alert Details

Use case Alert Details enables authorized users to access detailed information about an alerted equipment problem. A user clicks on the homepage notification/Alerts icon either upon submitting a damage report form or based on abnormal pattern detection. The user will be redirected from the homepage notification to the Alert Details webpage, which shows alert number, equipment, report on equipment condition, user comments, images, and status.

The alert status (for example, “Pending Review,” “Verified,” “Resolved”) can be updated by administrators and staff members, but only viewed by students.



5.3 Damage Trends Dashboard

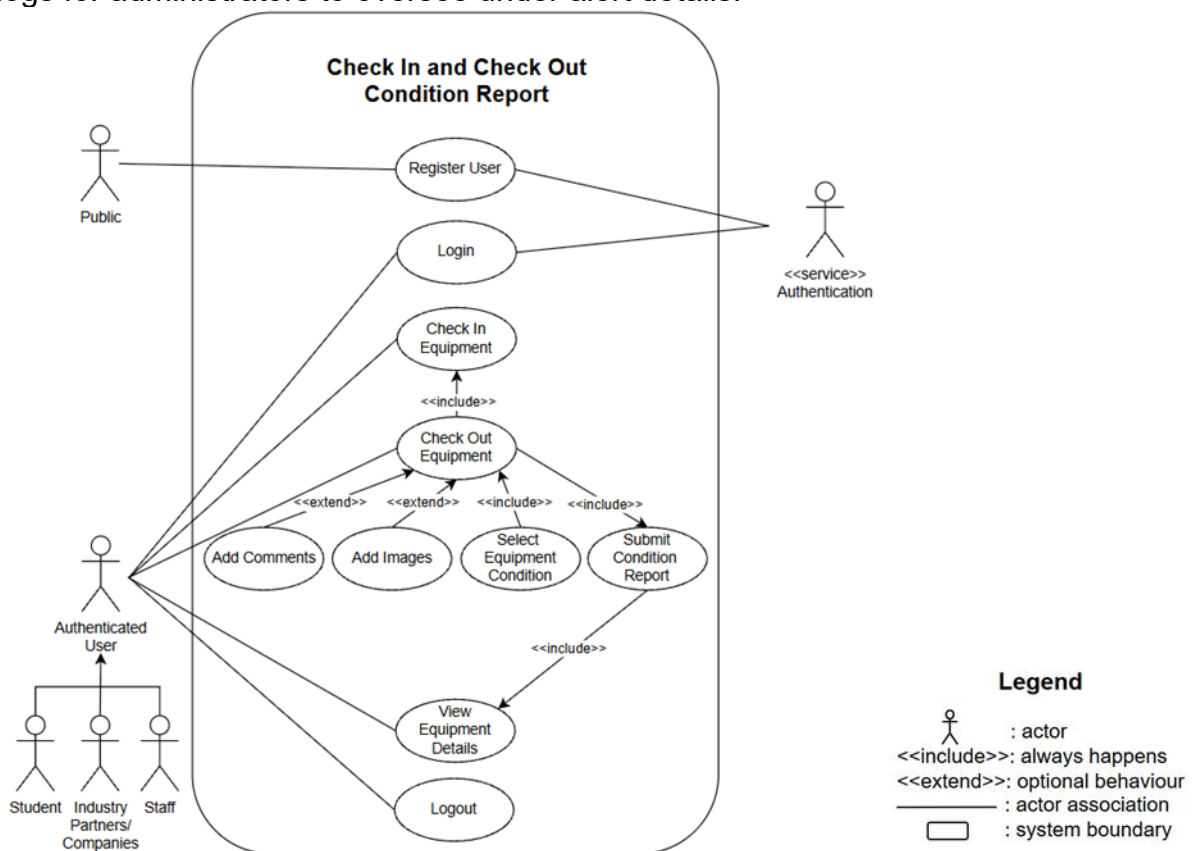
The Damage Trends Dashboard allows authorised technicians and administrators to view aggregated insights derived from historical equipment damage records, condition reports, and availability data. When accessing the dashboard, users are presented with summarised information that highlights recurring damage patterns, frequently damaged equipment, and common types of faults affecting equipment reliability.

By enabling users to examine damage trends across selected periods or categories, the dashboard supports analytical review and helps identify high-risk equipment and recurring operational issues. Presenting damage data in a consolidated and visual manner allows AMC staff to move beyond isolated incident handling and supports proactive maintenance planning, informed replacement decisions, and more efficient resource management. These insights enable staff to prioritise equipment for inspection, maintenance scheduling, or further investigation based on observed patterns.

Figure X: Use Case Diagram for Damage Trends Dashboard

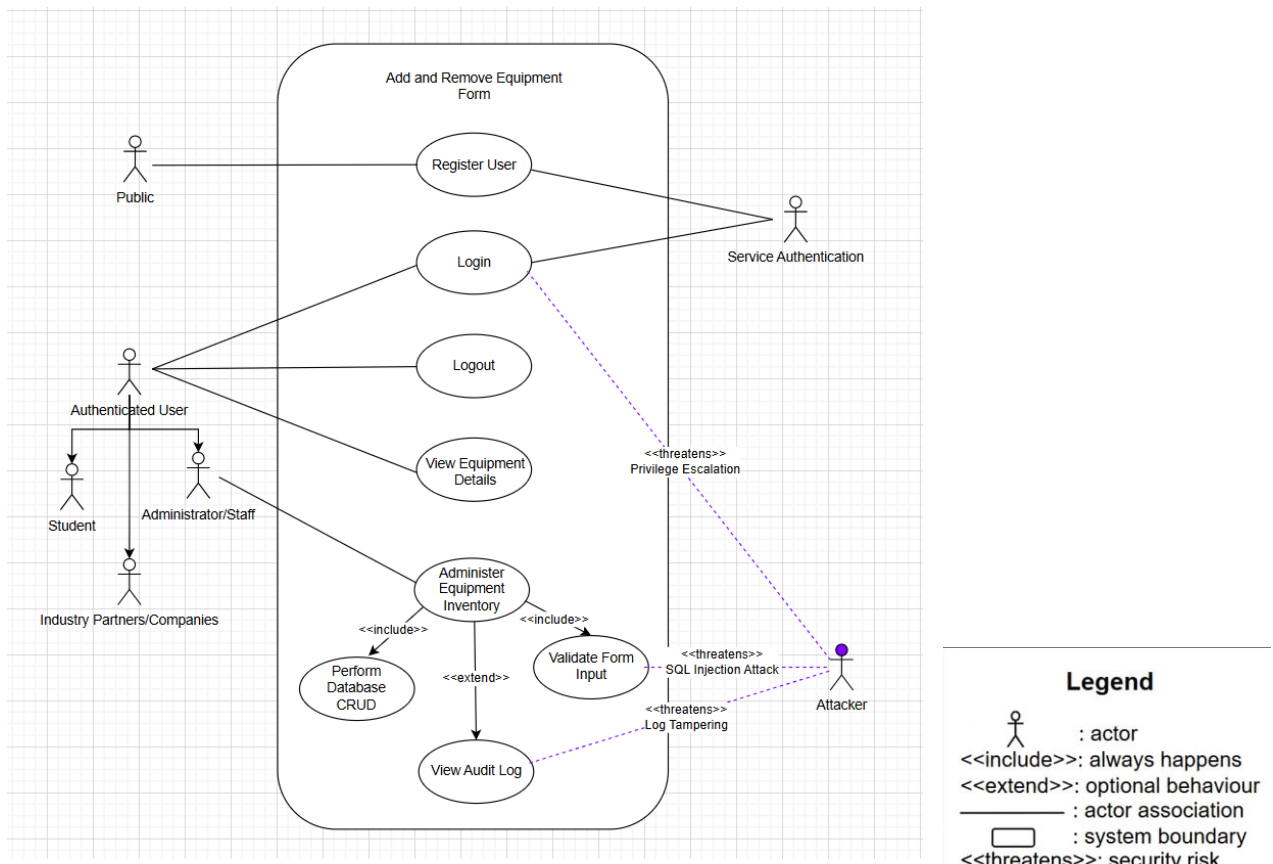
5.4 Check In and Check Out Condition Report

Authenticated users, students and staff, is required to check to use an equipment and to submit an equipment condition report when checking out the equipment used. This ensures user accountability and efficient logging for tracking. The condition report will prompt the user to select the equipment condition, “Very Bad”, “Bad”, “Neutral”, “Good” and “Very Good”. Optionally, the user can enter any comments and submit any supporting images. After submitting the condition report, the user will automatically be redirected to the updated equipment details page. This maintains accurate accountability, timely reporting of equipment health, and quick identification of equipment issues. This solves delays in reporting of equipment issues, inaccurate equipment condition data, and inconvenient reporting processes. It also provides logs for administrators to oversee under alert details.



6. Abuse/ Misuse Cases

6.1 Misuse Case for Add and Remove Equipment Form



Misuse Case 1: Privilege Escalation/Bypass (OWASP A01: Broken Access Control)

Attacker Goal	Unauthorized Inventory Deletion
Scenario	A malicious user successfully logs in but then exploits a flaw during the login phase to gain the higher Administrator/Staff privilege. This grants them unauthorized access to the Administer Equipment Inventory form, allowing them to delete or modify critical equipment records.
Impact	Causes massive data integrity loss and severe financial auditing failures. The system's foundational inventory data becomes unreliable, delaying projects and classes while assets are reported as missing.

Misuse Case 2: SQL Injection Attack (OWASP A03: Injection)

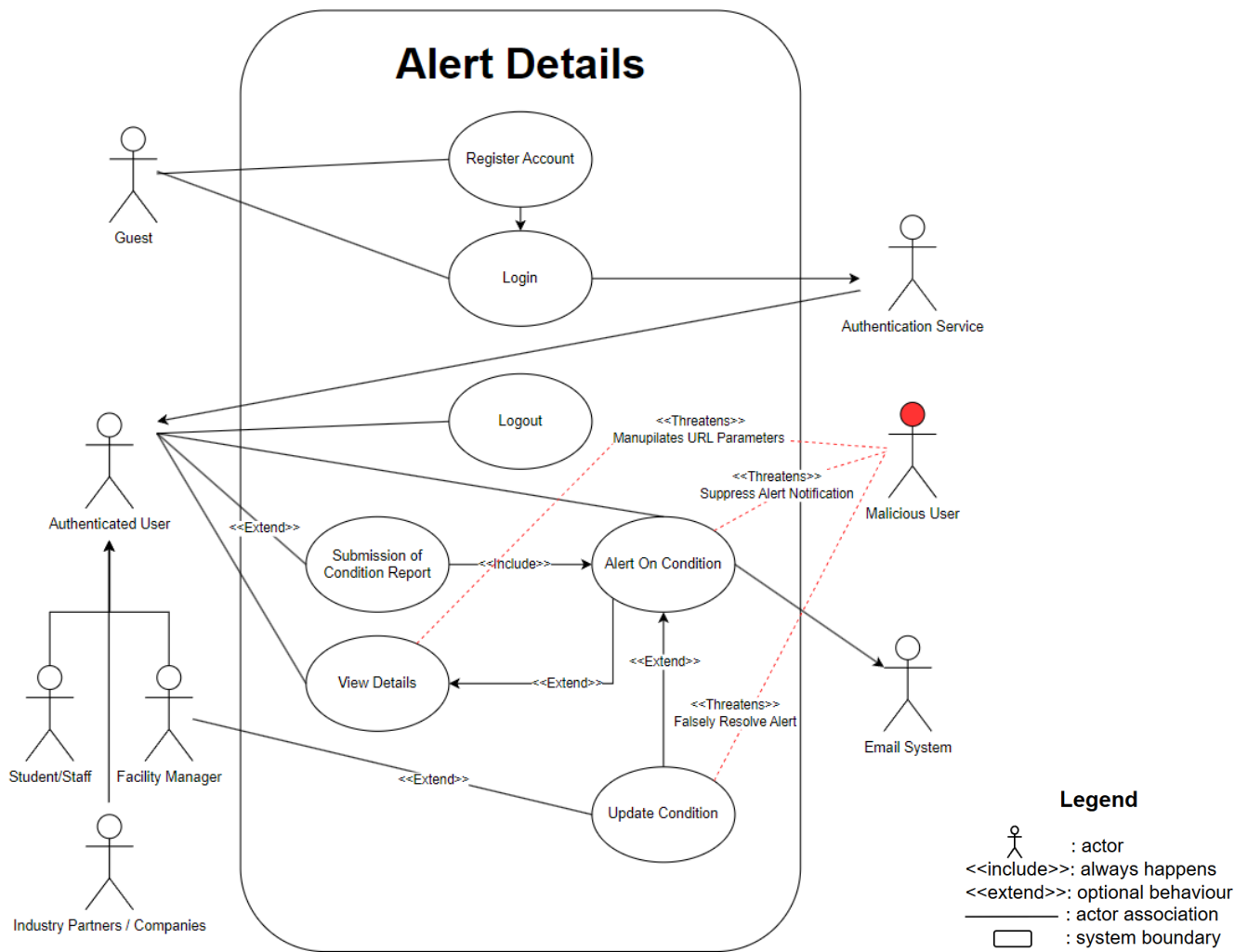
Attacker Goal	Corrupting Master Data via Input
Scenario	An attacker inserts malicious code, such as a SQL Injection payload, into a data field (e.g., equipment description) on the Add/Update Equipment Form. The system fails its mandatory Validate Form Input check and executes the malicious code directly in the database.

Impact	Leads to the mass deletion or unauthorized modification of the entire equipment inventory table. This compromises data integrity and confidentiality, resulting in the system becoming unusable until data is restored from backup.
--------	---

Misuse Case 3: Log Tampering (OWASP A10: Insufficient Logging and Monitoring)

Attacker Goal	Covering Tracks After Unauthorized Change
Scenario	A malicious Administrator successfully deletes a record. They then exploit a flaw in the logging service to modify or delete the corresponding Audit Log entry that recorded their action. This misuse is often paired with an injection or access control attack.
Impact	The lack of a secure, immutable log prevents security personnel from detecting who made the unauthorized change or when. This defeats accountability and allows the attacker to evade detection and repeat the misuse, leading to unrecoverable data loss.

6.2 Misuse Case for Alert Details



Misuse Case 1: Unauthorized Access to Alert Details (OWASP A01: Broken Access Control)

Attacker Goal	Accessing another user's alert information without authorized access or modifying the health records of equipment.
Scenario	A malicious user alters the value of the alert ID within the URI, for instance, from /alert-details?id=41 to /alert-details?id=42, to access privileged reports uploaded by other users. The malicious user could inject malicious scripts within the comments area or alter the status update request to indicate that a report is "Resolved."
Impact	Unauthorized access will compromise confidential user submissions such as images and comments. Vulnerabilities will make it difficult to identify actual equipment malfunction, thus influencing unsafe usage, inaccurate maintenance operations, and failures. It will affect the integrity and reliability of equipment management within the AMC.

Misuse Case 2: Concealment of Equipment Damage Alerts (OWASP A01: Broken Access Control)

Attacker Goal	To hide or suppress the appearance of authentic notifications of equipment damage in order to be able to continue working with damaged equipment.
Scenario	The attacker, whether malicious or negligent, uses the Alert Details page for an active equipment damage alert to make multiple changes to the alert status (for instance, from "Pending Review" to "Resolved") without actual reviews. The attacker might also use vulnerable authorization mechanisms to hide the alert before it is reviewed by the maintenance team, making the problem not reflected as active on the dashboard. Hence, the equipment is still marked as usable even though there is existing damage, which leads to the alert being closed prematurely.
Impact	This is because malfunctioning equipment is still delivered to customers, putting them at a high risk of injury. This practice also interferes with the historical health records and damage trends, resulting in incorrect maintenance practices. This affects the efficiency of the equipment health management process run by the AMC. It also affects the reliability of the alert mechanism used by the AMC.

6.3 Misuse Cases for Damage Trends

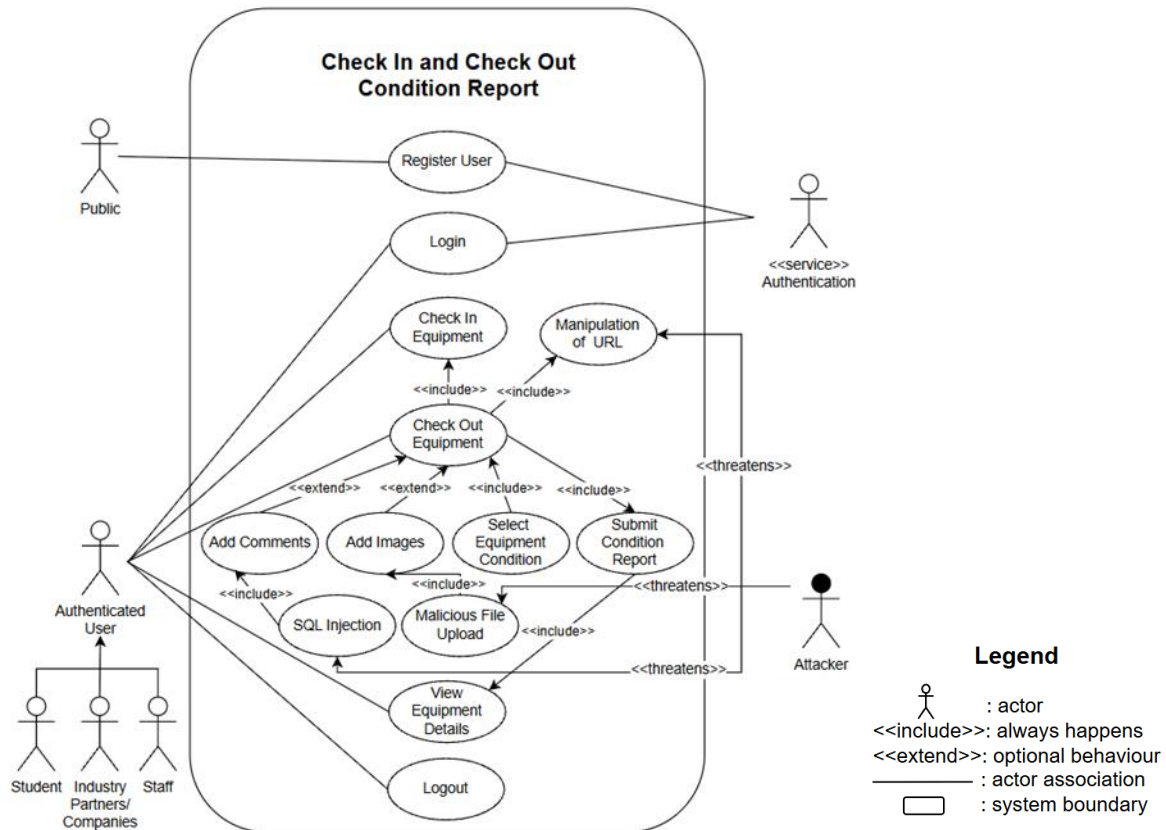
Misuse Case 1: Manipulation of Damage Trend Data

Attacker Goal	To alter or delete damage records in order to hide recurring equipment issues or present misleading statistics.
Scenario	An attacker with unauthorised access modifies historical damage records or removes entries that indicate frequent faults. As a result, the damage trends dashboard displays inaccurate information, preventing technicians and management from identifying problematic equipment.
Impact	Inaccurate trend analysis may lead to poor maintenance decisions, delayed repairs, and increased equipment downtime, ultimately affecting lessons and operations.

Misuse Case 2: Unauthorised Access to Damage Trends Dashboard

Attacker Goal	To view internal damage statistics without proper authorisation.
Scenario	A user without technician or administrator privileges gains access to the damage trends dashboard due to insufficient access controls.
Impact	Sensitive operational information may be exposed, leading to misuse of data or reputational concerns if internal maintenance issues are disclosed.

6.4 Misuse Case for Check In and Check Out Condition Report



Misuse Case 1: SQL Injection Attack (OWASP A03:2021)

Attacker Goal	To gain unauthorised access to manipulate or view equipment condition records in the database.
Scenario	An attacker uses a regular user account to the equipment check out page. While submitting the equipment condition report, under the comments field, the attacker enters malicious SQL payloads such as ' OR '1' = '1. This payload will be submitted with the intend of manipulating the backend query to view the records stored in the database. Without proper validation or sanitisation of the inputs, the database will execute the command, and the attacker will be able to view the records. This allows the attacker to retrieve, modify, or delete equipment condition records without being authorised.
Impact	Unauthorised modification or deletion of the equipment condition records can cause unreliable and inaccurate data being reported. Attackers will be able to very sensitive data causing issues in confidentiality. The data loses its integrity as any user can exploit this feature to alter the data. The inaccurate data would cause longer investigation periods, leading to lesser availability of the equipment and possible false accusations.

Misuse Case 2: Malicious File Upload (OWASP A05/ A06:2021)

Attacker Goal	To use malicious files to compromise the server or distribute malware.
Scenario	While submitting the condition report, the attacker can exploit the image upload feature by uploading a malicious file disguised as a legitimate image. For example, uploading image_name.jpg.php into the equipment condition report. Without proper checks for file extension types and enforce security storage, the malicious file will be uploaded successfully. The malicious may be executed accidentally by administrators on the server while checking through condition reports. When the file is executed, depending on what is in the file, a reverse shell can be establish or malwares, such as TrickBot and Qakbot, may infect the system.
Impact	Malicious files execution could expose sensitive information through reverse shells established. The malicious file uploaded may be malware as well. This can cause records to be modified, deleted or corrupted, affecting the integrity of the records. The malware may also cause the system to crash, leading to downtime of the web application.

Misuse Case 3: Manipulation of URLs (OWASP A03:2021)

Attacker Goal	To access or modify condition reports belonging to different users and equipment without authorisation.
Scenario	The attacker notices that the equipment condition report URL contains a predictable identifier. For example, the URL ends with /report/conditionReportID=1. The attacker will be able to manually edit the URL to /report/conditionReportID=2 to access, modify and tamper with another user's condition report.
Impact	The attacker can view another users' condition reports affecting the confidentiality of the reports. Since the attacker can also alter another's report, the integrity of the data is also affected. This can lead to longer investigation periods, causing longer downtime of equipment and possible false accusations.

7. Threat Modelling

7.1 Choice of Framework

Both STRIDE and DREAD are suitable, but STRIDE is more appropriate for this project because:

- It aligns with web application threat categories (Spoofing, Tampering, etc.)
- It is effective in classifying misuse cases that involve input manipulation and unauthorised access.
- STRIDE ties directly to common security controls like authentication, access control, logging, and secure coding.

For this reason, STRIDE is used for modelling the threats below.

7.2 Threat Analysis for Add and Remove Equipment Form

ID	System Component	Threat Type	Threat Description	STRIDE Category
1	Login	Privilege Escalation	An attacker bypass's role checks during or after the login phase to gain unauthorized Administrator/Staff privileges.	Elevation of Privilege (EoP)
2	Validate Form Input	Input Manipulation / Injection	An attacker inserts malicious SQL code into input fields (e.g., Asset Tag or Description), intending to execute the code during the database transaction.	Tampering
3	Perform Database CRUD	Data Tampering	An unauthorized user (via EoP) or successful injection directly alters, deletes, or modifies records in the master equipment inventory database.	Tampering
4	View Audit Log	Logging Bypass	An attacker modifies or deletes the log entry that recorded their unauthorized actions to evade accountability.	Repudiation

7.3 Threat Analysis for Alert Details

ID	System Component	Threat Type	Threat Description	STRIDE Category
----	------------------	-------------	--------------------	-----------------

1	Alert Details Page	URL Parameter	Attacker modifies alert ID to access unauthorized alerts	Elevation of Privilege / Information Disclosure
2	Comment/Description Input	Input Injection	Attacker inserts script or malicious input into comments to execute code	Tampering / XSS
3	Alert Status Update API	Privilege Misuse	Attacker attempts to access staff-only endpoints to change alert status	Spoofing / Elevation of Privilege
4	Alert Data Storage	Data Integrity	Attacker attempts SQL injection to modify or delete alert records	Tampering

7.4 Threat Analysis for Damage Trends Dashboard

ID	System Component	Threat Type	Threat Description	STRIDE Category
1	Damage Trends Dashboard	Data manipulation	Damage records are altered to falsify trend analysis	Tampering
2	Damage Trends Dashboard	Unauthorised access	Users access trend data without permission	Information Disclosure
3	Damage Records	Lack of accountability	Changes to damage data cannot be traced	Repudiation
4	Dashboard Access Control	Privilege escalation	Normal users gain admin-level access	Elevation of Privilege

7.5 Threat Analysis for Check In and Check Out Condition Report

ID	System Component	Threat Type	Threat Description	STRIDE Category
1	Comments in Equipment Condition Report	SQL Injection Attack (OWASP A03:2021)	An attacker enters malicious SQL payloads into the comments field to read, modify, or delete equipment condition data.	T – Tampering I – Information Disclosure
2	File Upload in Equipment Condition Report	Malicious File Upload (OWASP A05/ A06:2021)	An attacker uploads malicious files disguised as an image to execute scripts, spread malware and/ or compromise the server.	T – Tampering E – Elevation of Privilege D – Denial of Service

3	Check Out Equipment Condition Report URLs	Manipulation of URLs (OWASP A03:2021)	An attacker modifies the equipment condition report URL to access or modify reports belonging to other users.	I – Information Disclosure T – Tampering E – Elevation of Privilege
---	---	---------------------------------------	---	---

7.6 Mitigation Controls for Add and Remove Equipment Form

ID	Threat Addressed	Current Vulnerability	Mitigation Strategy
1	Privilege Escalation (EoP)	Role check failure after Login	Implement Step-up Authentication (Re-authentication): Even if the user is already logged in as Administrator/Staff, require them to re-enter their password or provide a second authentication factor before executing any sensitive transaction (e.g, Delete, or final Save/Update) within the Administer Equipment Inventory form.
2	Input Injection (Tampering)	Failure of Validate Form Input	Implement Strict Input Validation and Parameterized Queries: Use parameterized queries (Prepared Statements) for all CRUD operations. Strictly validate and sanitize all form input (length, type, and character escaping) <i>before</i> it reaches the database.
3	Data Tampering (Integrity)	Lack of secure logging	Implement Immutable Audit Logging: All Create, Update, and Delete (CRUD) operations must be logged immediately. Logs must be written to an immutable, secure service that only the system can append to, preventing any user (even an Administrator) from modifying or deleting existing log entries.
4	Data Tampering (Integrity)	Lack of accountability	Enforce Non-Repudiation through Digital Signature/Hashing. Before storing any sensitive CRUD operation (Add/Delete/Update), digitally sign or hash the entire transaction details, including the Administrator's ID and the action taken. Store this cryptographic signature securely in the Audit Log, making the entry tamper-proof and undeniable.

7.7 Mitigation Controls for Alert Details

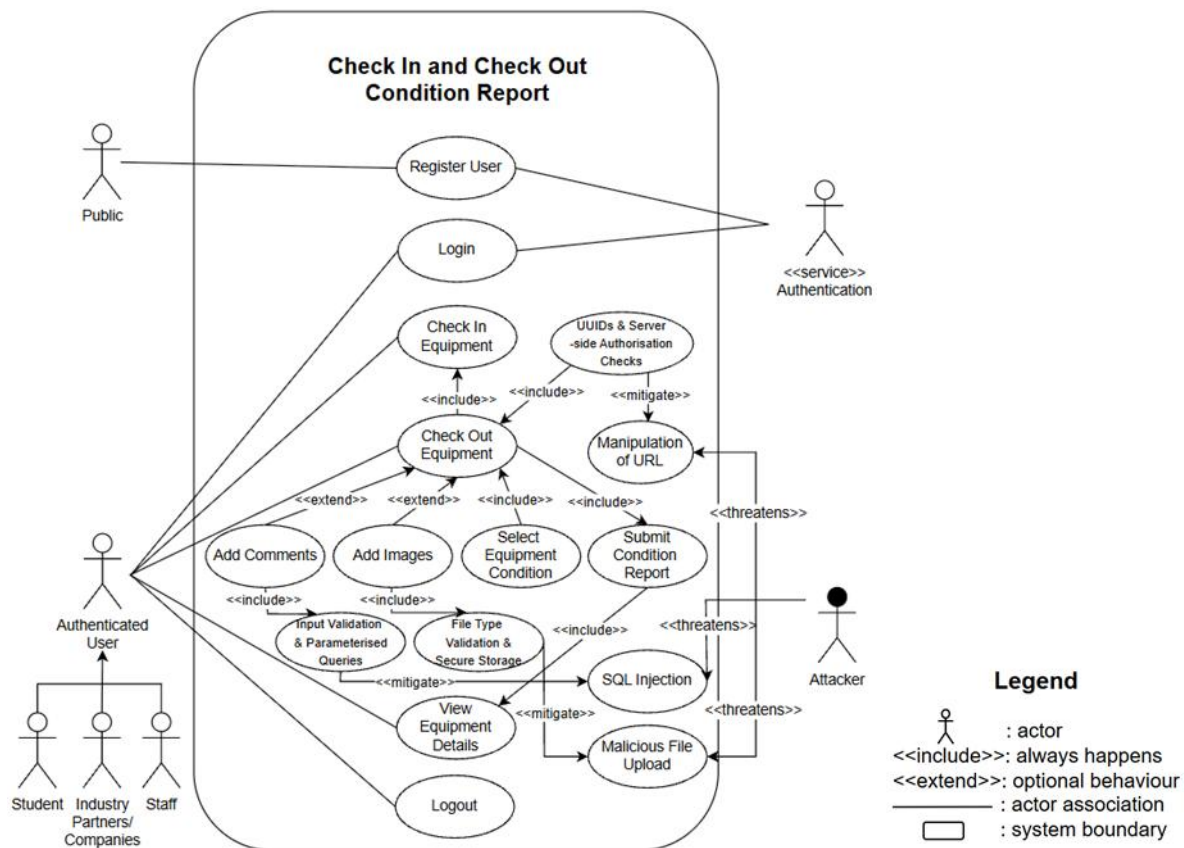
ID	Threat Addressed	Current Vulnerability	Mitigation Strategy
1	Unauthorized access via	Alert ID can be changed in URL	Enforce server-side RBAC checks; verify ownership and permissions before returning data

	URL manipulation		
2	XSS through comments	Comment fields accept raw text	Implement strict input validation, output escaping, and HTML sanitization
3	Privilege escalation on status updates	API endpoint not protected	Require role verification, CSRF tokens, and session validation for all modification requests
4	SQL Injection on alert queries	Dynamic SQL queries used	Use prepared statements with parameters, enforce database least privilege, monitor abnormal query patterns

7.8 Mitigation Controls for Damage Trends Dashboard

ID	Threat Addressed	Current Vulnerability	Mitigation Strategy
1	Data manipulation	No integrity checks on damage records	Role-based access control and audit logging
2	Unauthorised access	Weak access validation	Restrict dashboard to technician/admin roles
3	Repudiation	No activity logs	Maintain logs of all data modifications
4	Privilege escalation	Insufficient role enforcement	Server-side role verification

7.9 Mitigation Controls for Check In and Check Out Condition Report



1	SQL Injection Attack	SQL payloads are submitted through the comments field of the equipment condition report. This allows attacker to read, modify, or delete equipment condition data.	Input Validation Check and sanitise all user inputs to ensure only expected characters and formats are allowed. This prevents malicious SQL payloads being processed.
2			Parameterised Queries Use queries where user input is treated as data only, not as code. This prevents the execution of the SQL payloads entered.
3	Malicious File Upload	Malicious files disguised as images are submitted through the image field of the equipment condition report. This allows attackers to execute scripts, spread malware	File Type Validation Restrict uploads to safe file types such as JPG and PNG. Check file signatures to prevent the execution of malicious scripts disguised as images.
4			Secure Storage Store uploaded files in non-executable directories, rename files to prevent predictable paths, and perform malware scans often to prevent malicious execution.

		and/ or compromise the server.	
5	Manipulation of URLs	The equipment condition report URL contains predictable identifiers which	UUIDs Use random, unique identifiers for each equipment condition report to ensure it is difficult for attackers to guess valid IDs.
6		can be modified to access different pages. This allows attackers to access or modify reports belonging to other users.	Server-side Authorisation Checks Enforce permission verification on every request to ensure users can only access or modify resources they are authorised for. This ensures that even when the URL is manipulated, the user is still unable to access resources they are not authorised for.

8. Non-Functional Requirements

8.1 Security

8.1.1 Security in relation to Add and Remove Equipment Form

The primary security requirement dictates that the component must strictly enforce access control to protect the sensitive inventory data. Specifically, the system must prevent all unauthorized users from accessing the high privilege Administer Equipment Inventory interface. This requirement will be verified against a measurable standard: zero unauthorized attempts should successfully access the form upon security testing, which must be confirmed via rigorous server-side Role-Based Access Control (RBAC) validation.

8.1.2 Security in relation to ...

Damage trend data must only be accessible to authorised technician and administrator roles to protect the confidentiality of AMC's operational and maintenance information. Role-based access control (RBAC) will be enforced server-side to ensure that unauthorised users, such as students or general staff, are unable to view or manipulate damage trend analytics.

In addition, the damage trends dashboard must present information in a clear and understandable format so that authorised users can accurately interpret recurring equipment issues without requiring specialised technical knowledge. Clear presentation of damage data reduces the risk of misinterpretation, which could otherwise lead to incorrect maintenance decisions, delayed responses, or improper handling of faulty equipment.

To achieve these security requirements, access permissions will be validated on every request to the dashboard, and sensitive data will only be returned after successful role verification. All dashboard queries will be executed using parameterised SQL statements to prevent unauthorised data exposure, and user actions related to viewing or filtering damage trends will be logged for audit and accountability purposes.

8.1.3 Security in relation to Check In and Check Out Condition Report

NFR	How will it be achieved
Authentication	All users must log in with strong passwords and students must enter their admission number for accountability. The passwords enter must be at least 12 characters long with a mixture of uppercase, lowercase, numbers, and special characters. The students accounts have to be verified with their student matric card, ensuring user accountability. The account will also automatically lock after 5 failed attempts.

	This ensures only legitimate users can use the equipment and submit reports. This effectively prevents unauthorised actions and maintains accountability.
Authorisation	Role-based access control is done. Regular Users, such as students and staff, can only check in, check out and submit reports for the equipment they use. While administrators can view the reports in the database. This ensures that regular users cannot tamper with others' reports, maintaining the integrity of the logs as well.
Input Validation	Comments and file upload fields in the equipment condition report is sanitised and validated before the report is being submitted successfully. Only JPG and PNG file extension types can be submitted. Comments are being checked before being submitted. This ensure SQL injection and malicious file upload can not be done, protecting the system from attacks that could corrupts the database and the system. Keeping the submitted data safe ad reliable.
Data Protection	Encryption is done on the equipment condition report during submission, HTTPS. The data is not in plaintext during transit, preventing attackers from reading the record while network sniffing. This ensures that sensitive information about equipment usage and user activity stays confidential.
Audit and Logging	Check in and check out of equipment is being logged with timestamps, user ID, and equipment ID. The logs are being retained for 1 month. This provides traceable records. This supports accountability, helps resolve disputes, and allow administrators to investigate quickly.

8.1.4 Security in relation to Alert Details

Security Aspect	Requirement	Implementation / Control
Access Control	Only authorized users may view Alert Details relevant to their role	Role-based access control with server-side authorization checks
Data Ownership	Users may only access alerts they created or are assigned to	Ownership validation using user ID and alert ID mapping
Alert Modification	Only staff and administrators may update alert status	Privilege checks on alert update endpoints

Input Validation	All user inputs must be validated and sanitized	Server-side validation and output encoding
Session Security	All alert-related actions must be tied to authenticated sessions	Secure session tokens and expiry handling
Request Integrity	Status update requests must be protected from forgery	CSRF tokens for all state-changing requests
Audit Logging	All alert views and modifications must be logged	Timestamped logs with user identity and action details

8.2 Reliability

8.2.1 Reliability in relation to Add and Remove Equipment Form

To maintain user accountability and the trustworthiness of data history, the system is required to securely record all administrative actions. Every successful Create, Update, or Delete (CRUD) operation performed by an Administrator/Staff user must generate a complete, immutable log entry. The measurable standard for this is the Audit Log Integrity: every logged action must include the user ID, timestamp, action type, and the affected record ID, which must be secured by a successful cryptographic hash or digital signature upon logging to prevent tampering and ensure the log is a reliable record of events.

8.2.2 Reliability in relation to Alert Details

The Equipment Health and Alert Details modules should be designed such that the equipment condition information should be consistently logged, stored, and retrievable with no loss of data or corruption. Every health report and alert submission needs to be committed in the database using transaction integrity to prevent partial or incomplete data writes during system failures or interruptions over the network.

The system shall maintain a minimum of 99% availability to support continuous operational needs for health reporting and alert viewing functions. Mechanisms for error handling shall be put in place to ensure system failures do not result in broken pages or inconsistency in data. In the event of unexpected errors, the system shall return the application to a safe state while preserving previously submitted data.

The foreign key constraints will be enacted within the equipment records, alerts, and user accounts to maintain referential integrity. System and error logs will be generated for assisting in recovery and troubleshooting. In this way, consistent and dependable access to information on equipment health is ensured, reducing operational disruption.

8.2.3 Reliability in relation to Check In and Check Out Condition Report

NFR	How will it be achieved
Data Integrity	Database constraints such as certain columns like the equipment_id cannot be null and should be unique. Foreign keys such as equipment_id for referencing between tables to remain valid. This ensures the records from the equipment condition report is accurate and consistent. This prevents incorrect logging and maintains reliable reporting and accountability.

8.3 Compliance

8.3.1 Compliance in relation to Add and Remove Equipment Form

The system must comply with all relevant institutional policies governing data handling and asset tracking within the TP Advanced Manufacturing Centre (AMC). This is crucial for successful auditing and risk management. The measurable standard for this is Policy Compliance: all equipment records, audit logs, and user activity data must be securely retained and readily accessible for a minimum of seven years, ensuring alignment with the institution's financial auditing and data retention policies.

8.3.2 Compliance in relation to Alert Details

This shall include the treatment of user submissions and equipment records to be processed by the Equipment Health and Alert Details modules in accordance with institutional IT policies and responsible data handling practices. Personal information associated with alerts, such as user identifiers, comments, and images, should be stored securely and accessed only by authorized personnel.

Only designating roles should have access to alert modification functions, so accountability is maintained. Maintain audit logs for all alert status changes that identify the user making the change and timestamp of the change, allowing traceability and internal governance compliance. The system shall adhere to OWASP Top 10 secure development guidelines so as to minimize exposure to common web application vulnerabilities. Conformity to these standards ensures that the Equipment Management System operates securely, transparently, and accountably within the AMC environment.

8.4 Performance

8.4.1 Performance in relation to Add and Remove Equipment Form

The administrative functions must execute quickly to ensure efficient inventory management. The system is required to have a minimal processing time for both loading the inventory list and executing any data manipulation (Add, Update, Delete) request. The measurable standard for this is the Response Time: any single CRUD

operation must complete and return confirmation to the Administrator within 2 seconds, even while the system is under a modest operational load (e.g., 5 concurrent administrative users).

8.4.2 Performance in relation to Check In and Check Out Condition Report

NFR	How will it be achieved
Response Time	Report submission, check in, and check out is to be updated in 3 seconds by the system. Implement caching for frequently accessed data. This ensures that the data is updated in real-time ensuring efficient and no delays in reporting and operation. This also speeds up the check in, check out, and submission process.

8.4.3 Performance in relation to Alert Details

The modules of Alert Details and Equipment Health need to provide responsive performance in order to report and review equipment damage in a timely manner. Under normal operating conditions, the Alert Details page shall load in 3 seconds or less, even when historical alert data is present.

This will involve indexed equipment and alert identifiers in optimizing the performance of database queries. In retrieving historical health records, server-side pagination will be applied to prevent the loading of excessive data. Media files like images will be compressed and efficiently loaded to minimize delays in page rendering.

Performance testing will be carried out to determine the response time of the system at normal and peak conditions. This will ensure personnel can quickly analyze alerts and take necessary action without delays in the system.

8.5 Maintainability

8.5.1 Maintainability in relation to Add and Remove Equipment Form

To facilitate long-term maintenance and security updates, the code for the CRUD operations must be robust and well-structured. This requires securely separating the data access logic from the user interface and form handling. The measurable standard for this is the Layered Architecture: all database queries executed by this component must strictly utilize Parameterized Queries (Prepared Statements) and be physically located within a dedicated Data Access Layer (DAL) to prevent insecure dynamic query construction.

8.5.2 Maintainability in relation to Check In and Check Out Condition Report

NFR	How will it be achieved
-----	-------------------------

Logging and Documentation	Code for the web application follows coding standards, such as PSR-1: Basic Coding Standard, with appropriate inline comments and documentation. This ensures that troubleshooting, future maintenance and updates is easy to be handled, supporting long-term reliability of accountability features.
---------------------------	--

8.5.3 Maintainability in relation to Alert Details

Equipment Health and Alert Details modules should be designed to be maintainable, allowing for future enhancements, bug fixes, and policy changes without breaking existing functionality. The architecture of the system shall be modular, where alert management, equipment health tracking, and user access control should be implemented as separate components.

Concerns will be clearly separated into presentation at the front, logic at the back, and database access layers. All code involved in the processing and reporting of alerts and equipment health should be documented using naming conventions and comments to enhance readability and easiness in maintenance. Configuration values for instance, should include alert status types and role permissions, which can be updated without changing any code.

Version control will be used to track changes, and error logs will be maintained so any bugs can be diagnosed quickly. This also ensures ease of system maintenance and modification when the AMC's equipment policies or their operational needs change.

8.6 Usability

8.6.1 Usability in relation to Add and Remove Equipment Form

The user interface must be usable and reduce the risk of submission errors. The form is required to provide immediate, clear feedback to the Administrator/Staff user regarding any incorrect or improperly formatted input, preventing the submission of bad data. The measurable standard for this is the Form Validation: all required fields and input format checks must display a clear, client-side error message to the user who submits invalid data.

8.6.2 Usability in relation to Check In and Check Out Condition Report

NFR	How will it be achieved
User Interface and Feedback	Check in, check out, and submission have clear labels and visual indicators for validation errors, and confirmation messages. This reduces user mistakes when submitting reports and ensures accurate and reliable accountability.

8.6.3 Usability in relation to Alert Details

The Equipment Health and Alert Details modules need to be intuitive and user-friendly, which improves timely and accurate reporting of the conditions of equipment. It means that users can submit damage reports and access alert details in only a few steps without prior training.

The Alert Details page should communicate information to the user in a clear, organized manner, with elements such as equipment identification, description of the damage, images, timestamps, and current status included. The use of visual indicators on status labels-for example, "Pending Review," "Resolved"-will be implemented so that users can quickly and easily grasp the condition of any given equipment. Form fields should include clear labels and validation feedback to minimize submission errors.

It shall be consistent with the design of the overall web application, and shall be accessible across commonly used devices and screen sizes. These usability considerations in the interface ensure that there is higher user adoption, lower reporting errors, and efficiency in managing equipment health.

9. Test Plan / Considerations

9.1 Add and Remove Equipment Form

Security testing is mandatory to validate that the mitigation controls successfully neutralize the identified threats. This includes the Privilege Escalation Test, where a Student user must be blocked from accessing the administrative URL, ensuring strict Role-Based Access Control (RBAC). The SQL Injection Test validates that using a malicious payload (e.g., ' OR '1'='1' --) in an input field does not execute any unauthorized database commands, confirming that Parameterized Queries and input validation are functional. Furthermore, the Step-up Authentication Test verifies that critical actions like 'Delete' require a correct password re-entry, and the Log Tampering Test ensures that every successful 'Delete' action creates an immutable log entry that resists manual alteration, confirming system accountability.

Functional testing ensures the core business logic operates correctly. This plan includes four main tests covering the full data lifecycle. The Create Test verifies that filling the form and submitting a new record successfully adds it to the database and inventory list. The Read Test confirms that the entire equipment list, including correct status information (e.g., 'Available', 'Damaged'), is accurately displayed. The Update Test validates the process of modifying an existing record (e.g., changing its location) and ensuring the new value is correctly saved to the database. Finally, the Delete Test verifies that a selected record is permanently removed from the database after authorization, no longer appearing in the inventory.

Beyond core functionality, testing must validate that the system meets its quality standards (NFRs). Performance Testing requires using tools like Apache JMeter to simulate load and confirm that a single CRUD operation can be completed within the required 2-second Response Time. Usability Testing involves systematically using invalid inputs to verify that immediate, client-side error feedback is displayed within 500 milliseconds. Maintainability Testing (Code Review) ensures all database interactions utilize Parameterized Queries and are correctly encapsulated within a Data Access Layer. Finally, Compliance Testing verifies that the system's logging mechanism is configured to retain and maintain the accessibility of audit data for the specified seven-year period, meeting institutional policies.

9.2 Alert Details

Test scenarios for the Alert Details module would include checking that alerts are shown properly, are limited to authorized access, and are maintained properly. Important aspects to be covered during these tests include:

Functional Testing: Test if clicking on a notification leads to the loading of the correct alert. Test if all fields on an alert (status, description, images, and timestamps) are loaded properly. - **Authorization Testing**: Try manipulating URLs to gain access to alerts not belonging to yourself. Check if they result in an error message. Input Validation: Test comment sections with edge values, large strings, unusual characters, and XSS attacks. Status Update Testing: Check that status updates are

saved properly and updated live for staff user accounts. Also, make sure that students are unable to generate status update requests. Security Testing

Test for SQL injection attacks, CSRF attacks, and XSS attacks. Error Handling: Introduce missing alert IDs, deleted alerts, and invalid queries to force error-safe responses from the module. The module will be continuously tested against the Equipment Health workflow with a focus on ensuring that alert details shown on the Alert Details page are reflected from check-in and check-out reports.

9.3 Damage Trends Dashboard

Testing will be conducted to ensure that the damage trends dashboard accurately displays aggregated data from damage records and condition reports. Access control testing will be performed to verify that unauthorised users are unable to view the dashboard. Additionally, integrity testing will confirm that modifications to damage records are logged and reflected correctly in trend analysis. Performance testing will also be conducted to ensure that dashboard queries remain responsive when processing large volumes of historical damage records.

9.4 Check In and Check Out Condition Report

There are 5 types of testing to be conducted to ensure the check in and check out condition report feature to function:

1. Unit Testing
2. Integration Testing
3. Security Testing
4. System Testing
5. User Acceptance Testing (UAT)

Testing will be carried out from the 14th of January 2026 to 27th of January 2026 as stated in the Gantt Chart. With key milestones for unit testing and integration testing on 20th of January 2026, security testing on 24th of January 2026, and UAT on 27th of January 2026.

The testing objectives are to verify that:

1. Authorised users can check equipment in and out correctly
2. Condition Reports are captured accurately
3. System is protected from common web attacks
4. All NFRs are met correctly

Testing is to be done with a combination of automated tools and manual tools. Automated tests can be done on PHP functions while manual testing for UI behaviour. Security testing can be done with OWASP tools. Use realistic usage scenarios for a complete testing of the whole function.

Testing Type	Test ID	Test Description	Test Steps	Expected Results	Actual Result	Pass/Fail	Notes
Unit	TC - 01	Check in with user account	1. Navigate to register account	Check in success	(to be filled)	(to be filled)	(to be filled)

			2. Log into the account made 3. Check in an equipment				
	TC - 02	Submit condition report with valid inputs	1. Navigate to Condition Report 2. Enter valid inputs under comments, image, and condition fields 3. Submit condition report	Report saved success	(to be filled)	(to be filled)	(to be filled)
	TC - 03	Submit condition report with invalid inputs	1. Navigate to Condition Report 2. Enter invalid inputs under comments, image, and condition fields 3. Submit condition report	Validation error returned	(to be filled)	(to be filled)	(to be filled)
Integration	TC - 04	Alerts made when condition is bad	1. Navigate to Condition Report 2. Enter "Bad" or "Very Bad" for the condition field 3. Submit condition report 4. Check alert details as admin	Alert made	(to be filled)	(to be filled)	(to be filled)
Security	TC - 05	SQL injection blocked	1. Navigate to Condition Report 2. Enter invalid inputs under comments	Validation error returned	(to be filled)	(to be filled)	(to be filled)

			field (' OR '1'='1') 3. Submit condition report				
	TC - 06	Malicious file upload blocked	1. Navigate to Condition Report 2. Enter invalid inputs image upload field (image.php) 3. Submit condition report	Validation error returned	(to be filled)	(to be filled)	(to be filled)
	TC - 07	URL cannot be manipulated	1. Navigate to Condition Report 2. Attempt to alter the URL to access different pages	No predictable identifier to access different pages	(to be filled)	(to be filled)	(to be filled)
System	TC - 08	Whole workflow from login to logout	1. Navigate to register account 2. Log into the account made 3. Check in an equipment 4. Navigate to Condition Report 5. Enter valid inputs under comments, image, and condition fields 6. Submit condition report 7. Log out of the account	Report saved success	(to be filled)	(to be filled)	(to be filled)
UAT	TC - 09	Live walkthrough done for tutor during	1. Navigate to register account	Tutor approves	(to be filled)	(to be filled)	(to be filled)

		the final presentation	2. Log into the account made 3. Check in an equipment 4. Navigate to Condition Report 5. Enter valid inputs under comments, image, and condition fields 6. Submit condition report 7. Log out of the account				
--	--	------------------------	---	--	--	--	--

The condition report is considered successfully completed and passed when:

1. All test cases return expected outputs (passed)
2. No runtime errors
3. No critical security issues found
4. All features function correctly
5. Tutor/ stakeholders confirms system meets requirements

10. Workload Distribution

Student Name	Admin Number	Contribution
Abdul Kapoor Asbar Firas	2403219E	• Introduction - Solution: Real-Time Equipment Condition & Damage Tracking System • Problem Statement - Equipment Health • Web Application Proposal - Equipment Health • Project Delivery - Development Phase - Testing Phase • Use Cases - Alert Details • Abuse/ Misuse Cases - Misuse Case for Alert Details • Threat Modelling - Threat Analysis for Alert Details - Mitigation Controls for Alert Details • Non-Functional Requirements - Security: Alert Details - Reliability: Alert Details - Compliance: Alert Details - Performance: Alert Details - Maintainability: Alert Details - Usability: Alert Details • Test Plan / Considerations - Alert Details
Haja Najumudeen Mohamed Hasif	2400251A	• Introduction 1.1 introducing the team • Problem Statement 2.1 Equipment Availability • Web Application Proposal 3.1 Equipment Availability • Project Delivery 4.7 Documentation Phase

		4.8 Presentation Phase • Use Cases 5.1 Add and Remove Equipment Form • Abuse/Misuse Cases 6.1 Misuse Case for Add and Remove Equipment Form • Threat Modelling 7.2 Threat Analysis for Add and Remove Equipment Form 7.6 Mitigation Controls for Add and Remove Equipment Form • Non-Functional Requirements 8.1.1 Security in relation to Add and Remove Equipment Form 8.2.1 Reliability in relation to Add and Remove Equipment Form 8.3.1 Compliance in relation to Add and Remove Equipment Form 8.4.1 Performance in relation to Add and Remove Equipment Form 8.5.1 Maintainability in relation to Add and Remove Equipment Form 8.6.1 Usability in relation to Add and Remove Equipment Form • Test Plan/Considerations 9.1 Add and Remove Equipment Form
Loke Si Xuan	2400542C	• Introduction – Main Problem • Problem Statement – User Accountability • Web Application Proposal – User Accountability • Project Delivery – Gantt Chart, Planning Phase

		• Use Cases - Check In and Check Out Condition Report • Abuse / Misuse Cases – Check In and Check Out Condition Report • Threat Modelling – Threat Analysis for Check In and Check Out Condition Report, Mitigation Controls for Check In and Check Out Condition Report • Non-Functional Requirements – Security in relation to Check In and Check Out Condition Report, Reliability in relation to Check In and Check Out Condition Report, Performance in relation to Check In and Check Out Condition Report, Usability in relation to Check In and Check Out Condition Report, Maintainability in relation to Check In and Check Out Condition Report • Test Plan / Considerations – Check In and Check Out Condition Report
Naw May Thet Htar	2403220C	• Introduction - Brief Overview • Problem Statement - Damage Trends • Web Application Proposal - Damage Trends • Project delivery - Overview - Design Phase • Use Cases - Damage Trends Dashboard • Abuse / Misuse Cases - Misuse Cases for Damage Trends • Threat Modelling - Threat Analysis for Damage Trends Dashboard • Non-Functional Requirements - Security • Test Plan / Considerations - Damage Trends dashboard

11. References / Acknowledgements

Asbar

Hasif

- <https://www.tp.edu.sg/research-and-industry/centres-of-excellence/centres-under-school-of-engineering/advanced-manufacturing-centre.html>
- Grammarly – To correct grammar errors

Si Xuan

- <https://www.tp.edu.sg/research-and-industry/centres-of-excellence/centres-under-school-of-engineering/advanced-manufacturing-centre/advanced-manufacturing-centre-smart-factory.html>
- <https://www.tp.edu.sg/research-and-industry/centres-of-excellence/centres-under-school-of-engineering/advanced-manufacturing-centre.html>
- <https://www.sciencedirect.com/science/article/pii/S0950584915000993>
- <https://www.scirp.org/journal/paperinformation?paperid=47628>
- <https://www.php-fig.org/psr/psr-1/>

Naw May

12. Appendix

-